



Intrusion detection



Prevention vs. detection

- ◆ Firewalls (and other security mechanisms) aim to *prevent* intrusion
- ◆ IDS aims to *detect* intrusion in case it occurs
- ◆ Use both in tandem!
 - Defense in depth
 - Full prevention impossible
 - The sooner intrusion is detected, the less the damage
 - IDS can also be a deterrent, and can be use to detect weaknesses in other security mechanisms



IDS overview

◆ Goals of IDS

- Detection and response
- Deterrence
- Recovery
- Defense against future attacks

◆ Two classes of behavior to be detected

- Illegal access by outsiders
- Illegal access by insiders



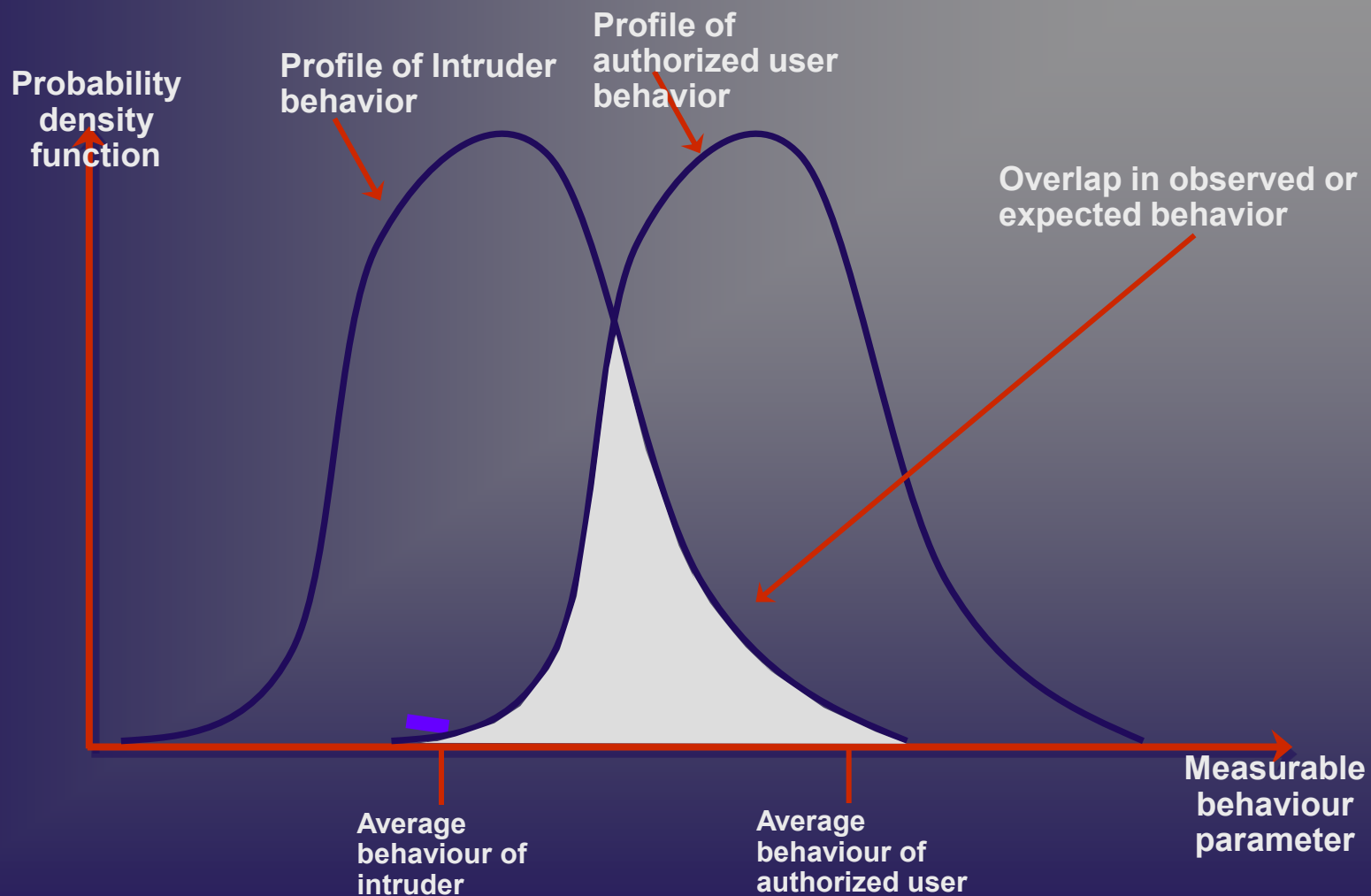
IDS tradeoff

- ◆ IDS based on the assumption that *attacker behavior is (sufficiently) different from legitimate user behavior*
- ◆ In reality, there will be overlap
 - Some legitimate behavior may appear malicious
 - Intruder can attempt to disguise their behavior as that of an honest user



False positives/negatives

- ◆ False positive
 - Alarm triggered by acceptable behavior
- ◆ False negative
 - No alarm triggered by illegal behavior
- ◆ Always a tradeoff between the two...
 - Note: credit card companies face the same tradeoff





False alarms?

- ◆ Say we have an IDS that is 99% accurate
 - I.e., $\Pr[\text{alarm} \mid \text{attack}] = 0.99$ and $\Pr[\text{no alarm} \mid \text{no attack}] = 0.99$
- ◆ An alarm goes off -- what is the probability that an attack is taking place?
- ◆ To increase this probability, what should we focus on improving??



False alarms

- ◆ Say the probability of an attack is 1/1000
- ◆ Use Bayes' law:
$$\begin{aligned}\Pr[\text{attack} \mid \text{alarm}] &= \Pr[\text{alarm} \mid \text{attack}] \Pr[\text{attack}] / \Pr[\text{alarm}] \\ &= 0.99 * 0.001 / (0.99 * 0.001 + 0.01 * 0.999) \\ &\approx 0.1\end{aligned}$$
- ◆ I.e., when an alarm goes off, 90% of the time it will be a false alarm!
- ◆ How best to lower this number?



Host-based IDS

- ◆ Monitors events on a single host
- ◆ Can detect both internal and external intrusions
- ◆ Two general approaches
 - Anomaly detection
 - Signature (rule-based) detection



Anomaly detection

- ◆ Monitor behavior and compare to some “baseline” behavior using statistical tests
 - Look for deviations from “normal behavior”
- ◆ “Normal behavior” can be defined on a global level or a per-user level
- ◆ “Normal behavior” can be specified by a human, or learned automatically over time



Anomaly detection

- ◆ Threshold detection
 - Looking at frequency of occurrence of various events, within a specific period of time
 - Even if attacker can thwart this, it will slow the attack
- ◆ Profile-based (statistical anomaly detection)
 - Look at changes from a user-specific “baseline”
 - Baseline behavior can be derived from audit records
 - Can look at outliers from the mean, or more complicated (multivariate) data; in either case, need to define some appropriate metric for when unusual behavior is detected



Metric	Model	Justification
Login frequency by date and time	Mean and standard deviation	Intruders are more likely to login during off-hours
Frequency of login at different locations	Mean and standard deviation	Intruders may login from a location that a legitimate user does not
Time since last login	Markov (time series)	Break-in to unused account
Length of session	Mean and standard deviation	Masquerader may run a much shorter or longer session
Large amount of data copied to some location	Mean and standard deviation	Detect attempt to copy large amounts of sensitive data
Password failures at login	Unusual event/operational	Detect attempt to guess passwords



Signature (rule-based) detection

- ◆ Define a set of “bad patterns” (e.g., known exploits or known bad events)
- ◆ Detect these patterns if they occur
- ◆ Anomaly detection $\approx$ looks for atypical behavior
- ◆ Signature detection $\approx$ looks for improper behavior



Example rules

- ◆ Users should not read files in other users' personal directories
- ◆ Users must not write to other users' files
- ◆ Users who log in after hours often use the same files they used earlier
- ◆ Users do not generally open disk devices directly, but rely on higher-level OS utilities
- ◆ Users should not be logged in more than once to the same system
- ◆ Users do not make copies of system programs



Distributed host-based IDS

- ◆ Combine information collected at many different hosts in the network
- ◆ One or more machines in the network will collect and analyze the network data
 - Audit records needs to be sent over the network
 - Confidentiality and integrity of the data must be preserved
 - Centralized architecture: single point of data collection/analysis
 - Decentralized architecture: More than one analysis center – more robust, but must be coordinated



Network-based IDS

- ◆ Monitors traffic at selected points on the network
 - Real time; packet-by-packet
- ◆ Host-based IDS – looks at user behavior, activity on host, local view
- ◆ Network-based IDS – looks at network traffic, global view



Sensor types

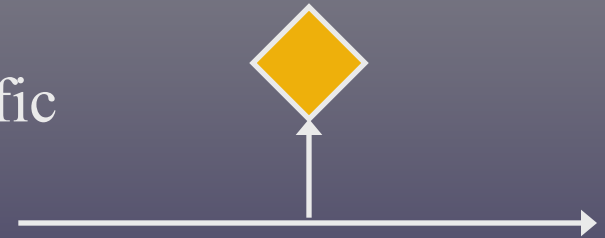
- ◆ Inline sensor

- Inserted in network path; all traffic passes through the sensor



- ◆ Passive sensor

- Monitors a copy of network traffic



- ◆ Passive sensor more efficient; inline sensor can block attacks immediately



Sensor placement

◆ Inside firewall?

- Can detect attacks that penetrate firewall
- Can detect firewall misconfiguration
- Can examine outgoing traffic more easily to detect insider attacks
- Can configure based on network resources being accessed (e.g., configure differently for traffic directed to web server)

◆ Outside firewall?

- Can document attacks (types/locations/number) even if prevented by firewall (can then be handled out-of-band)



Honeypots

- ◆ Decoy systems to lure potential attackers
 - Divert attackers from critical systems
 - Collect information about attacker's activity
 - Delay attacker long enough to respond
- ◆ Since honeypot is not legitimate, any access to the honeypot is suspicious
- ◆ Can have honeypot computers, or even honeypot networks



Honeypot placement

◆ Outside firewall

- Can detect attempted connections to unused IP addresses, port scanning
- No risk of compromised system behind firewall
- Does not divert internal attackers

◆ Fully internal honeypot

- Catches internal attacks
- Can detect firewall misconfigurations/vulnerabilities
- If compromised, run the risk of a compromised system



Firewalls



Firewalls: overview

- ◆ Provide central “choke point” for all traffic entering and exiting the system
- ◆ Main goals
 - Service control – what services can be accessed (inbound or outbound)
 - Behavior control – how services are accessed (e.g., spam filtering, web content filtering)
 - User/machine control – controls access to services on a per-user/machine level



Firewalls: overview

◆ Other goals

- Auditing (see also intrusion detection)
- Network address translation
- Can also run security functionality, e.g., IPSec, VPN

◆ What they cannot protect against

- Do not offer full protection against insider attacks
- Users bypassing the firewall to connect to the Internet
- Infected devices connecting to network internally



Firewalls: overview

- ◆ Positive filter
 - Allow only traffic meeting certain criteria
 - I.e., the default is to reject
- ◆ Negative filter
 - Reject traffic meeting certain criteria
 - I.e., the default is to accept



Need for firewalls?

- ◆ Why not *just* provision each computer with its own firewall/IDS?
 - Not cost effective
 - Different OS's make management difficult
 - Patches must be propagated to all machines in the system
 - Does not protect against insider attacks that extend beyond the local network
- ◆ Defense in depth
 - Can also have per-host firewalls as well



Packet filtering

- ◆ Apply a set of rules to each incoming/outgoing packet
- ◆ Packet filtering may be based on any part(s) of the traffic header(s), e.g.:
 - Source/destination IP address
 - Port numbers
 - Flags
 - Network interface (e.g., reject packet with internal IP address if coming from the wrong interface)



Disadvantages of packet filtering

- ◆ Can be difficult to configure rules to achieve both usability and security
 - E.g., ftp uses a dynamically-assigned port number for the data transfer
- ◆ Misconfigurations can be easily exploited
- ◆ Does not examine application-level data
- ◆ No user authentication
- ◆ Does not address inherent TCP/IP vulnerabilities
 - E.g., address spoofing

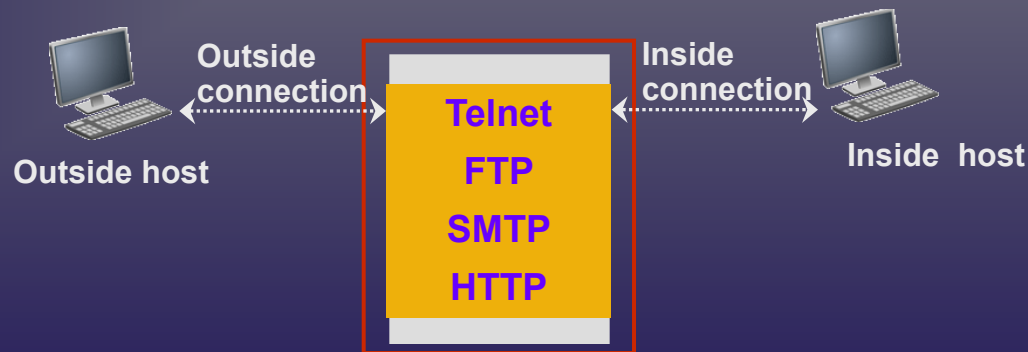


Stateful firewalls

- ◆ Typical packet filtering applied on a packet-by-packet basis
- ◆ Can also look at *context*
 - E.g., maintain list of active TCP connections (useful when port number are dynamically assigned)
 - E.g., look at sequence numbers and detect replays
- ◆ Can also use global information (e.g., number of packets to/from a particular IP address)

Application-level gateways

- ◆ Acts as an application-level proxy for users
 - Each “logical” connection is actually two TCP connections
 - If particular application is not supported, that application is not allowed





Application-level gateways

◆ Advantages

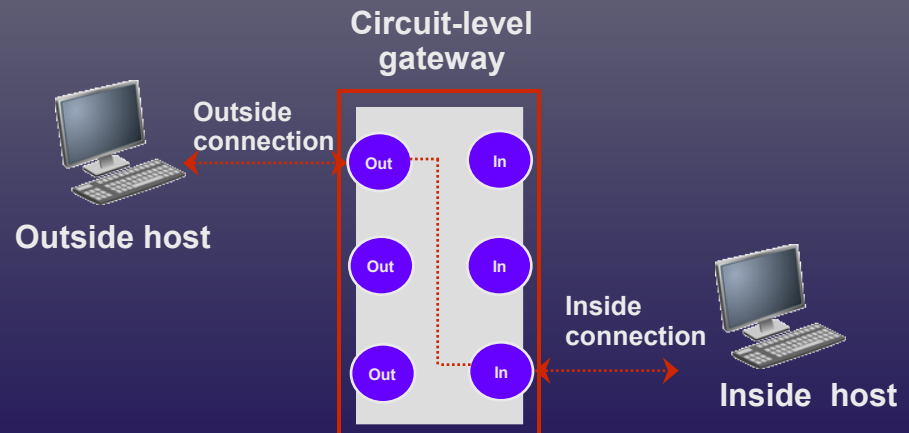
- Restricted number of applications to worry about
- Can examine application-level traffic for potential vulnerabilities
- Can provide user authentication
- More secure than packet-based filtering

◆ But...

- Higher processing overhead

Circuit-level gateways

- ◆ As with application-level gateways, circuit-level gateways set up two TCP connections:
- ◆ Once connections are established, TCP segments are forwarded *without examining their contents*
 - The security function consists of determining which connections are allowed



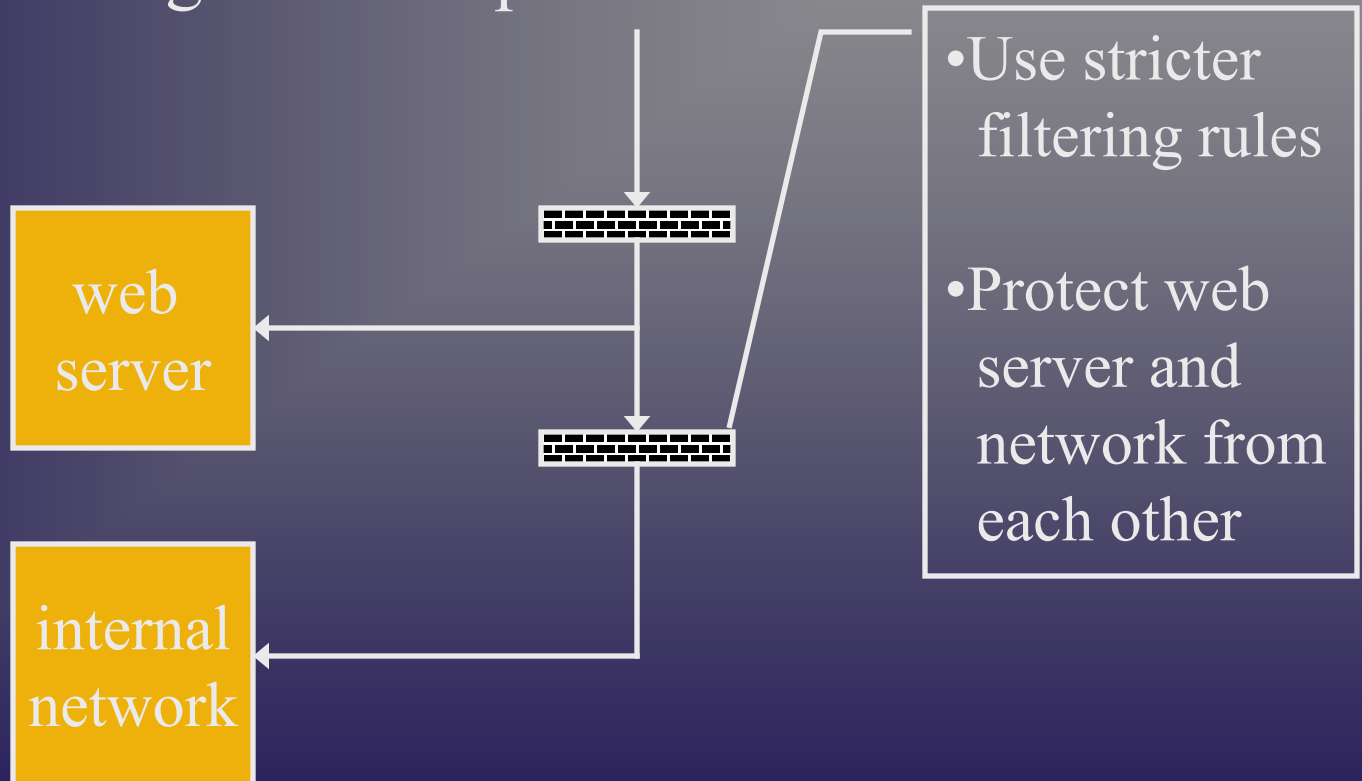


Host-based firewalls

- ◆ Can be used on machines that are not part of a larger network (e.g., home machines)
- ◆ Can also provide additional protection within a larger network
- ◆ Filtering can be machine-specific

Multiple firewalls

- ◆ Can have multiple network firewalls, each providing different protection





VPNs and IPSec

- ◆ Can use a firewall to allow for encrypted and authenticated communication across the Internet
 - If done behind the firewall, the firewall cannot analyze packets
- ◆ Used in conjunction with IPSec, which does encryption/authentication at the IP layer

